Simulación y Análisis de Intrusión con Persistencia en Entorno Windows

Proyecto Mini-SOC – Análisis de Incidente de Seguridad

Autor: Javier Afonso

Especializacion: *Ciberseguridad – SOC Analyst Training*

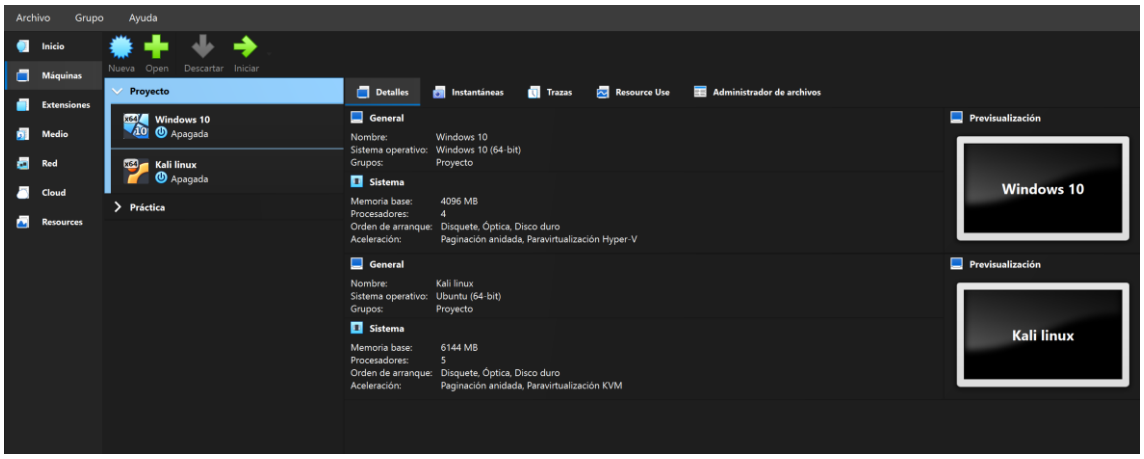
Año: 2026

ÍNDICE

1. Introducción 1
2. Objetivos del proyecto 2
3. Descripción del entorno de laboratorio 3
4. Configuración de red y conectividad 4
5. Simulación del ataque de fuerza bruta RDP 5
6. Generación de intentos fallidos de autenticación 6
7. Análisis de eventos de seguridad (ID 4625) 7
8. Análisis y correlación completa del incidente 8
9. Conclusión 9

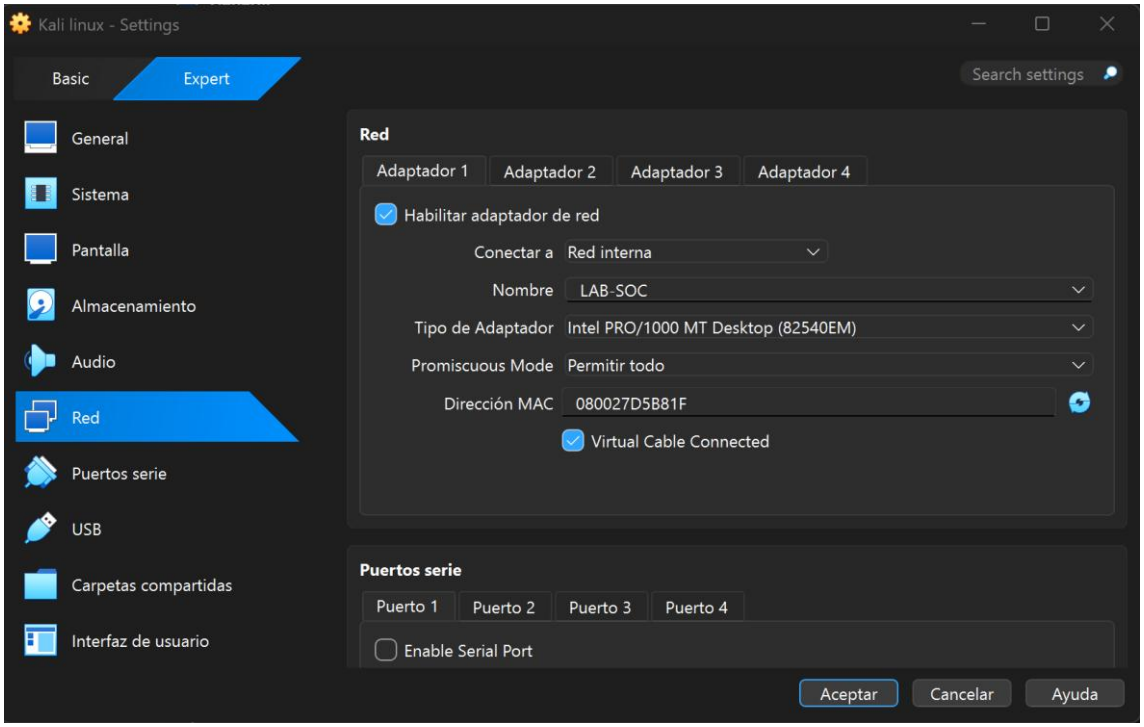
1) Arquitectura del entorno

Se presenta el entorno virtualizado del laboratorio, compuesto por una máquina Kali Linux (atacante) y una máquina Windows 10 (víctima), utilizado para simular y analizar un incidente de intrusión con persistencia en un segmento aislado.

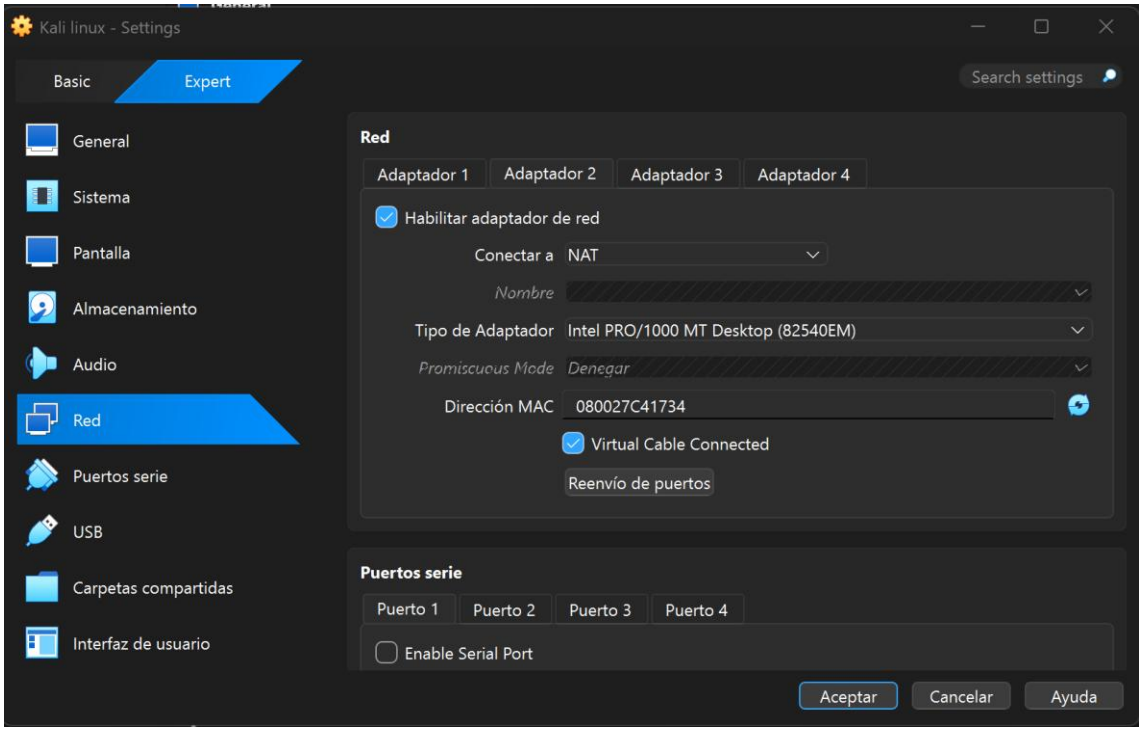


2) Configurar red en VirtualBox

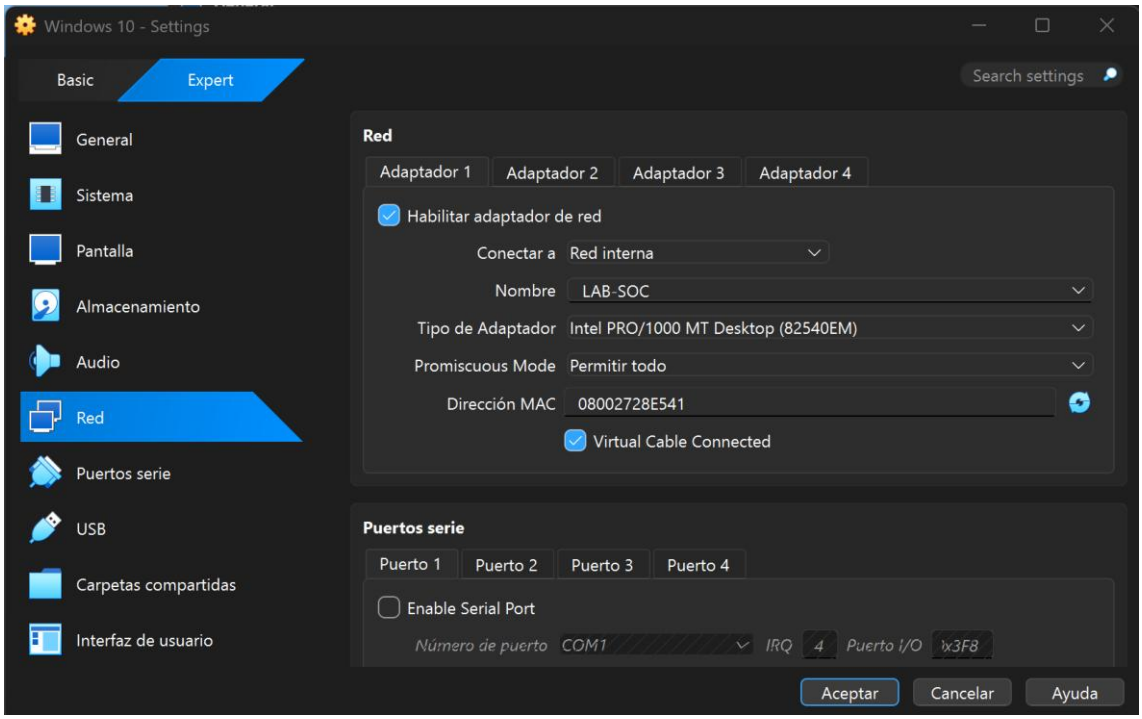
Se configura Kali en la red interna LAB-SOC para generar tráfico de ataque dentro de un entorno aislado y controlado.



Se configura Kali en la red interna LAB-SOC para generar tráfico de ataque dentro de un entorno aislado y controlado.

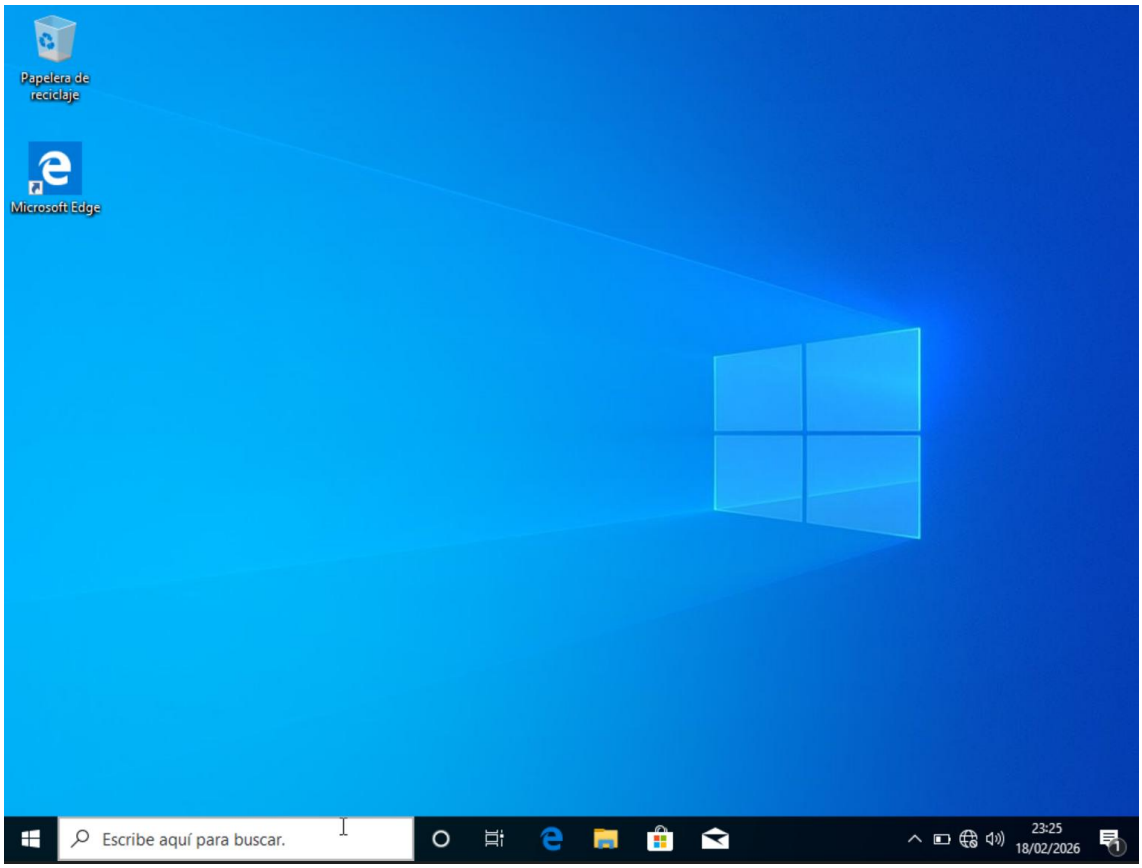


Windows 10 se integra en la misma red interna LAB-SOC para permitir la simulación de accesos remotos y la generación de evidencias en registros del sistema.



3) Encendido ordenado y estado inicial

Se inicia primero la máquina víctima para asegurar que los servicios del sistema y la conectividad de red estén operativos antes de comenzar la simulación del incidente.



Se inicia la máquina atacante para realizar verificaciones de red y ejecutar la actividad simulada desde un origen controlado.

4) IPs y conectividad

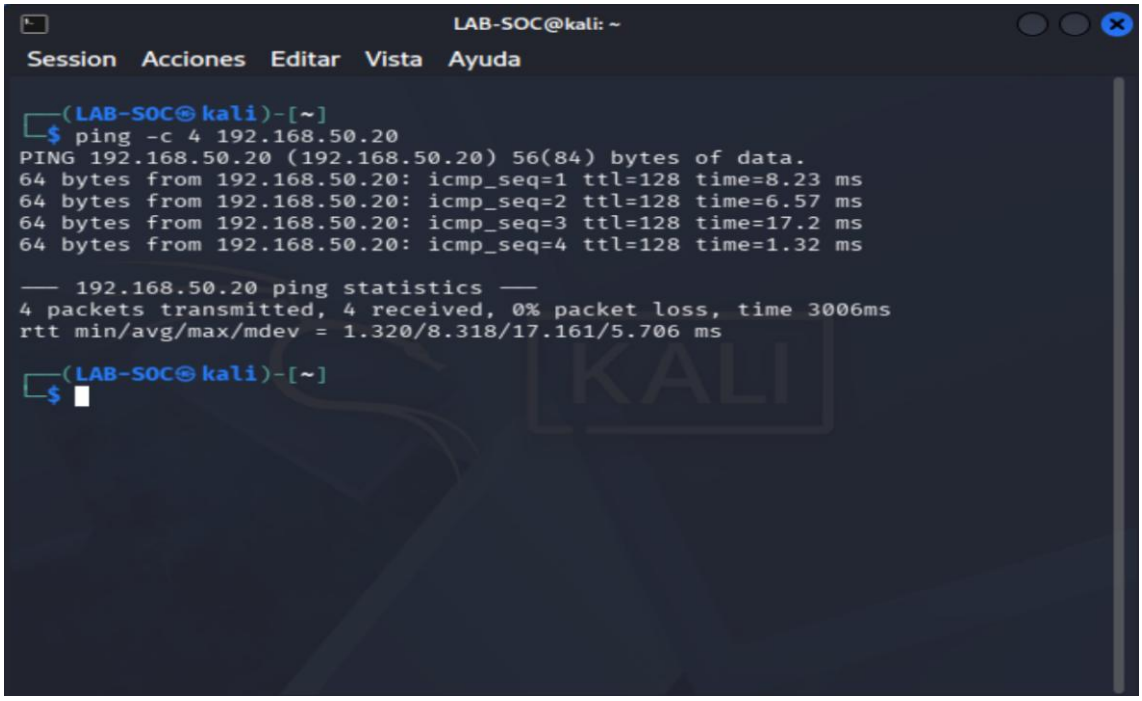
Se verifica la dirección IP del sistema Windows 10 para identificar el host objetivo en el laboratorio y facilitar la correlación de eventos.

```
Símbolo del sistema
Microsoft Windows [Versión 10.0.18362.30]
(c) 2019 Microsoft Corporation. Todos los derechos reservados.

C:\Users\LAB-SOC>ipconfig

Configuración IP de Windows


Adaptador de Ethernet Ethernet:

   Sufijo DNS específico para la conexión. . :
   Vínculo: dirección IPv6 local. . . : fe80::a9fc:4f8:a9d9:31dc%5
   Dirección IPv4. . . . . . . . . . . . : 192.168.50.20
   Máscara de subred . . . . . . . . . . . : 255.255.255.0
   Puerta de enlace predeterminada . . . . . :

C:\Users\LAB-SOC>
```

Se verifica la dirección IP de Kali Linux, que será utilizada como origen del tráfico (IOC) durante el incidente simulado.

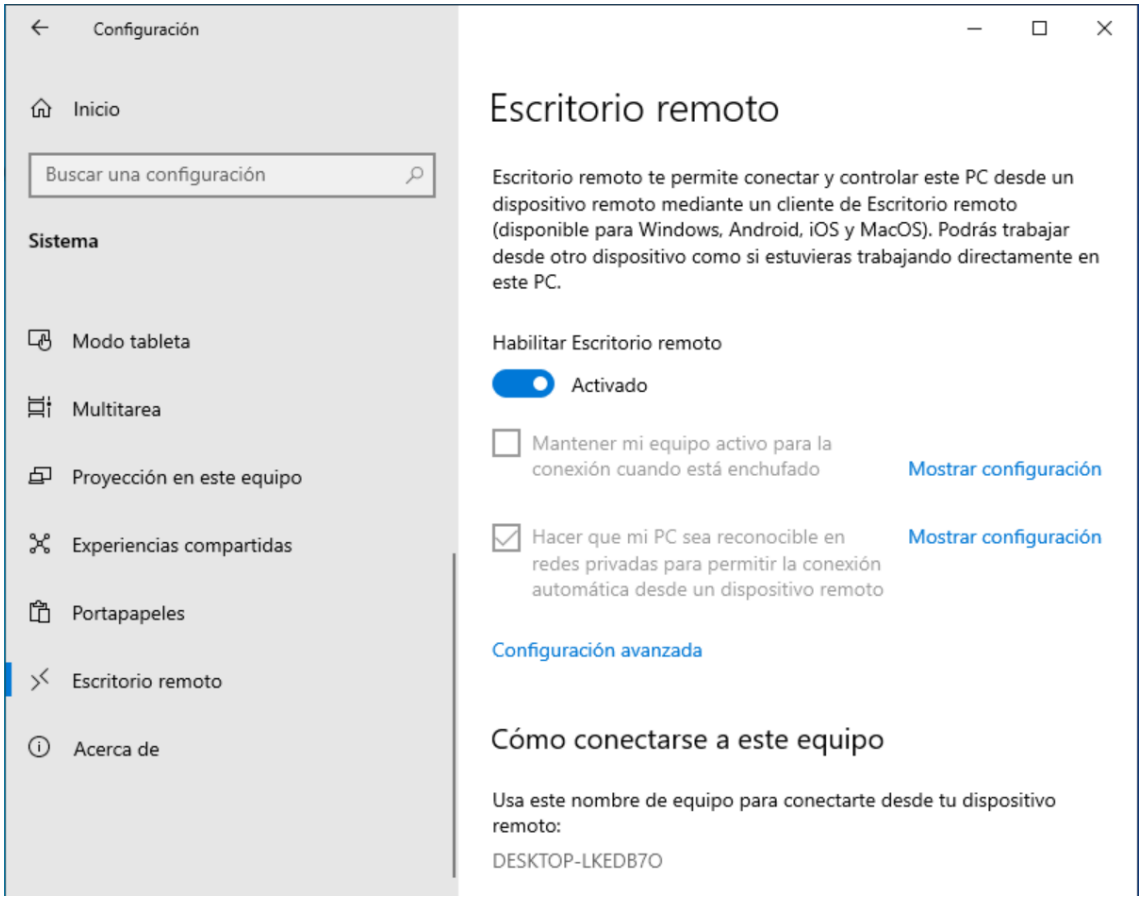
```
LAB-SOC@kali: ~
Session  Acciones  Editar  Vista  Ayuda

┌──(LAB-SOC㉿kali)-[~]
└─$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group def
ault qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP g
roup default qlen 1000
    link/ether 08:00:27:d5:b8:1f brd ff:ff:ff:ff:ff:ff
    inet 192.168.50.10/24 scope global eth0
       valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP g
roup default qlen 1000
    link/ether 08:00:27:c4:17:34 brd ff:ff:ff:ff:ff:ff
    inet 10.0.3.15/24 brd 10.0.3.255 scope global dynamic noprefixroute eth1
       valid_lft 86120sec preferred_lft 86120sec
    inet6 fd17:625c:f037:3:2096:c151:c6f1:5150/64 scope global temporary dyna
mic
       valid_lft 86123sec preferred_lft 14123sec
    inet6 fd17:625c:f037:3:a00:27ff:fec4:1734/64 scope global dynamic mngtmpa
ddr noprefixroute
       valid_lft 86123sec preferred_lft 14123sec
    inet6 fe80::a00:27ff:fec4:1734/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
```

Se valida la conectividad previa entre atacante y víctima para asegurar que la simulación y las evidencias posteriores no se deban a fallos de red.

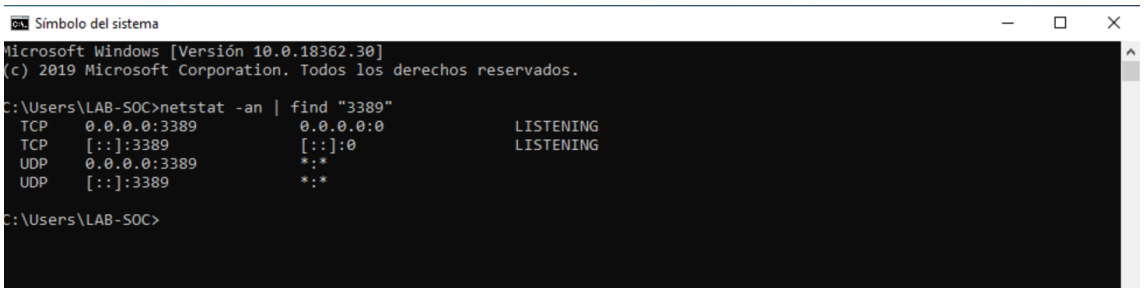


5) Preparación de Windows para auditoría

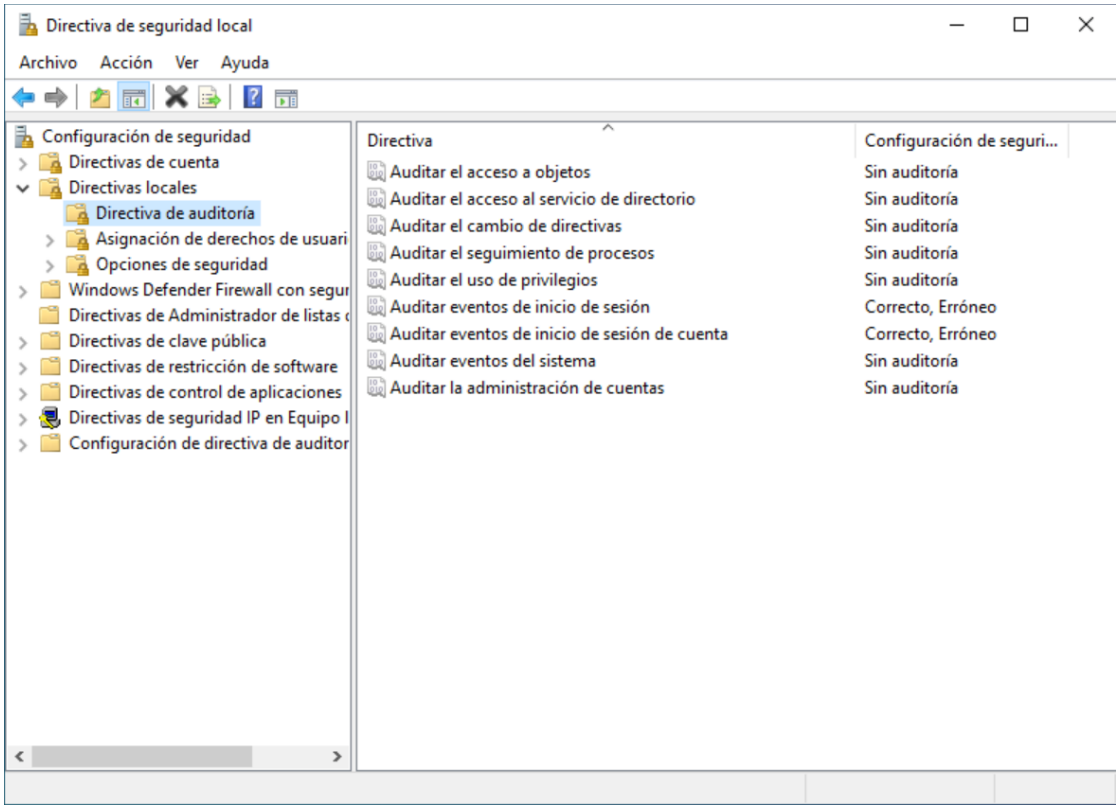
Se habilita el servicio de Escritorio remoto (RDP) en Windows 10 para simular un acceso remoto y generar evidencias de autenticación en los registros de seguridad.



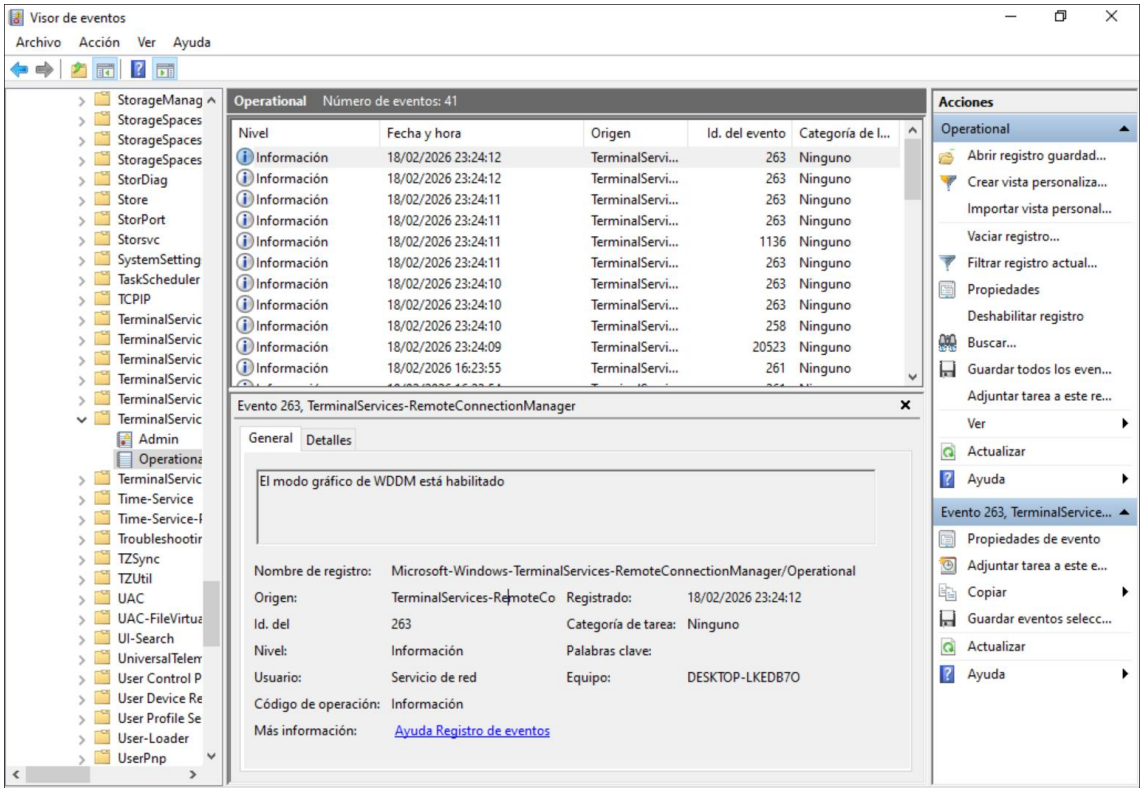
Se confirma que el servicio RDP se encuentra activo y escuchando en el puerto TCP/3389.



Se habilita la auditoría de inicios de sesión exitosos y fallidos para registrar la actividad de autenticación relacionada con el incidente.

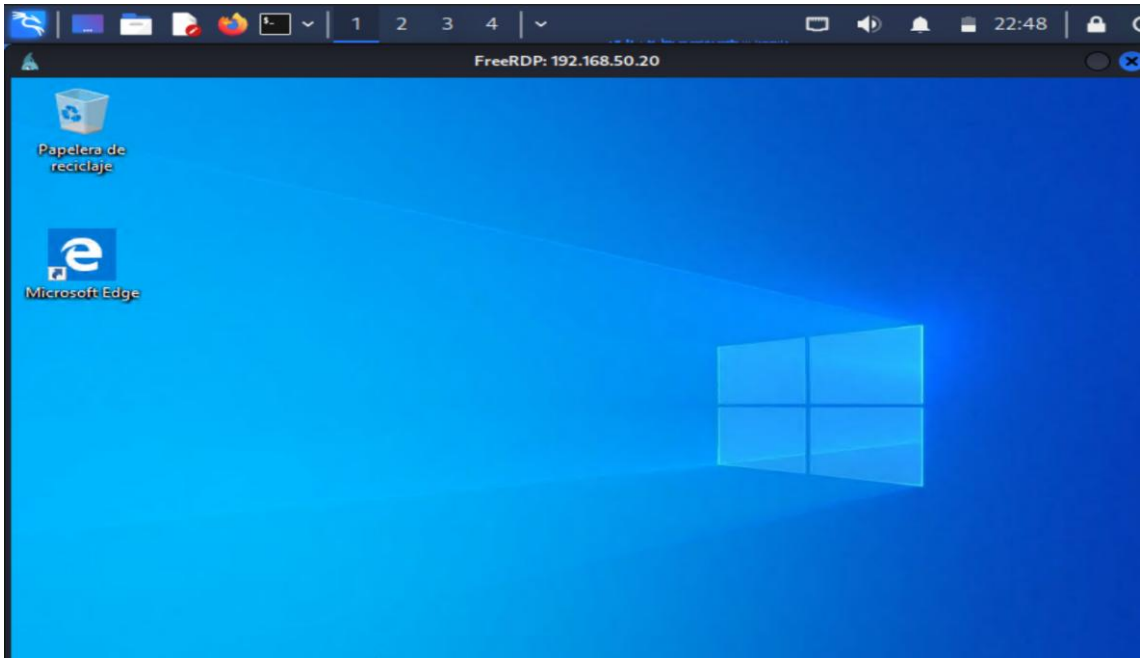


Se habilita el registro operacional de RDP para complementar el Security Log con eventos específicos de conexiones remotas.



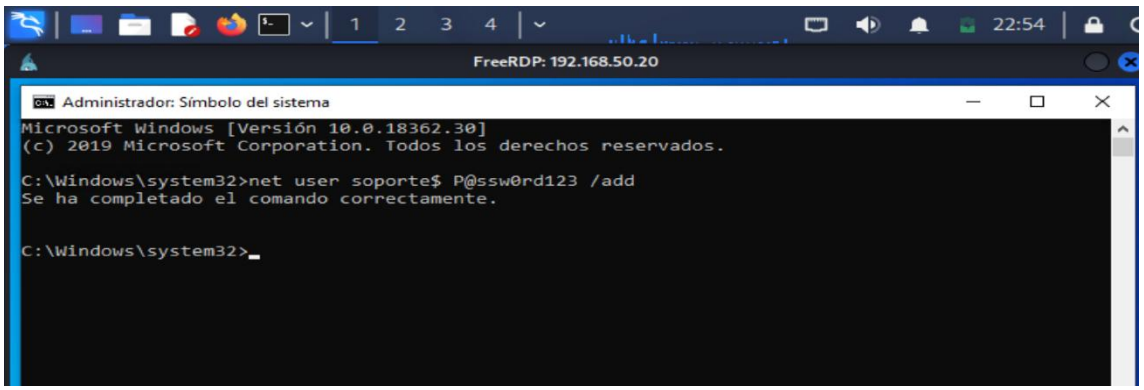
6) Simulación del Incidente

Se establece conexión RDP exitosa desde la máquina Kali (192.168.50.10) hacia Windows 10 (192.168.50.20), generando un evento 4624 (inicio de sesión exitoso) en el registro de seguridad.

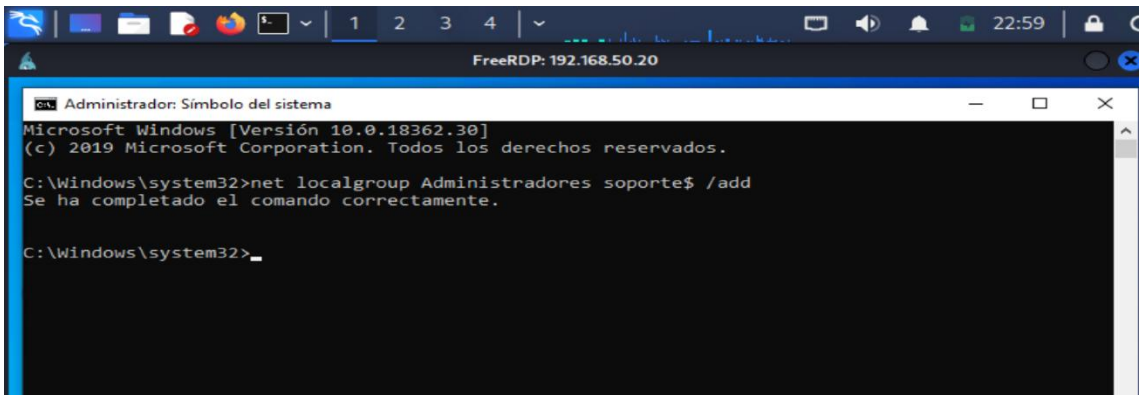


En la imagen anterior hay que ejecutar el comando **“xfreerdp3 /v:192.168.50.20 /u:LAB-SOC /p:Contraseña real de la maquina victima /cert:ignore”**

Tras obtener acceso al sistema, se crea una cuenta local denominada “soporte$”, acción que genera el evento 4720 (creación de cuenta).

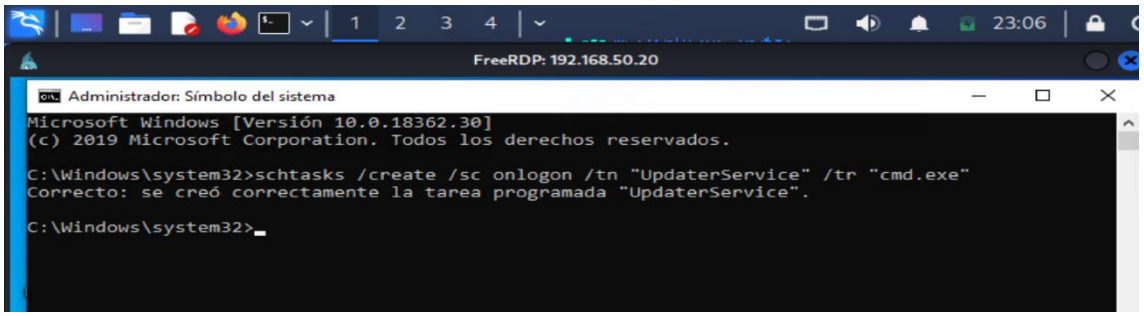


La cuenta creada es añadida al grupo Administradores, generando el evento 4732, lo que permite al atacante mantener privilegios elevados en el sistema.

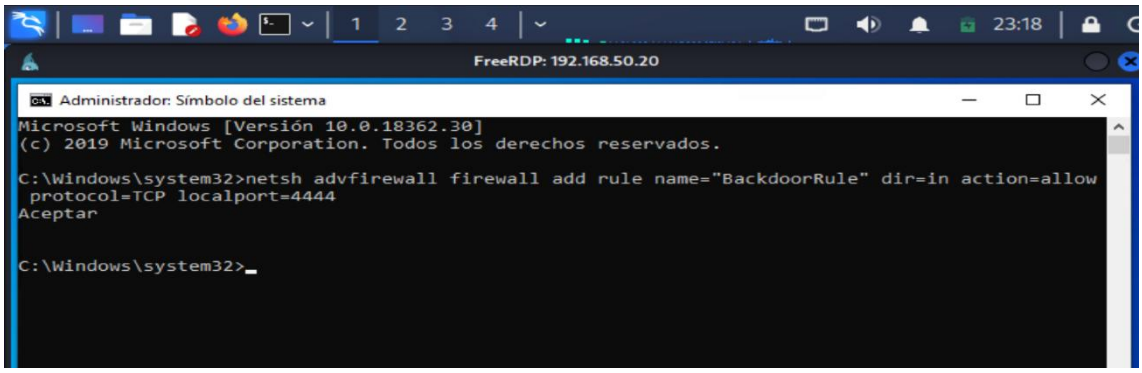


Se crea una tarea programada denominada “UpdaterService”, generando el evento 4698, técnica utilizada comúnmente para establecer persistencia tras el compromiso inicial.

“schtasks /create /sc onlogon /tn "UpdaterService" /tr "cmd.exe"

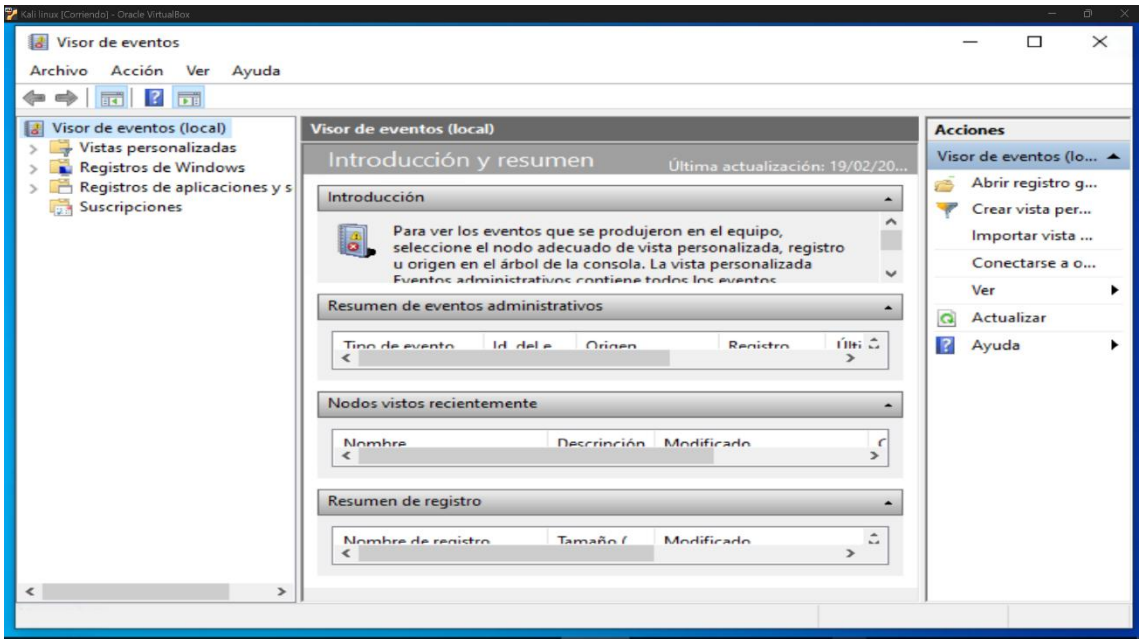


Se modifica la configuración del firewall añadiendo una nueva regla de entrada, acción que puede asociarse a técnicas de evasión y establecimiento de acceso persistente.

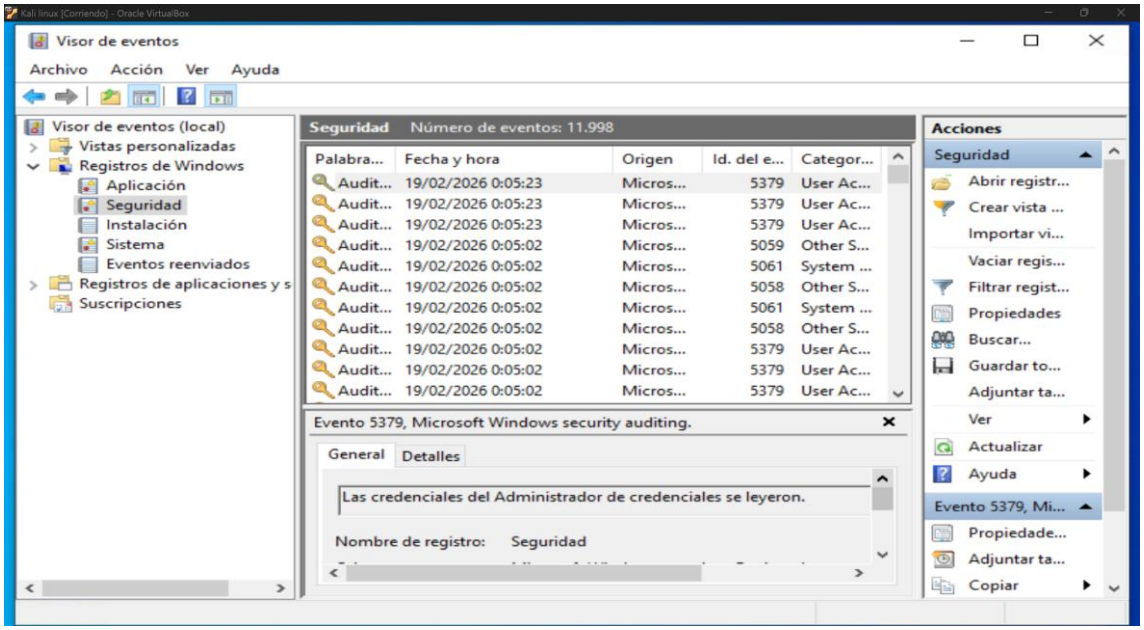


7) Análisis y correlación completa del incidente

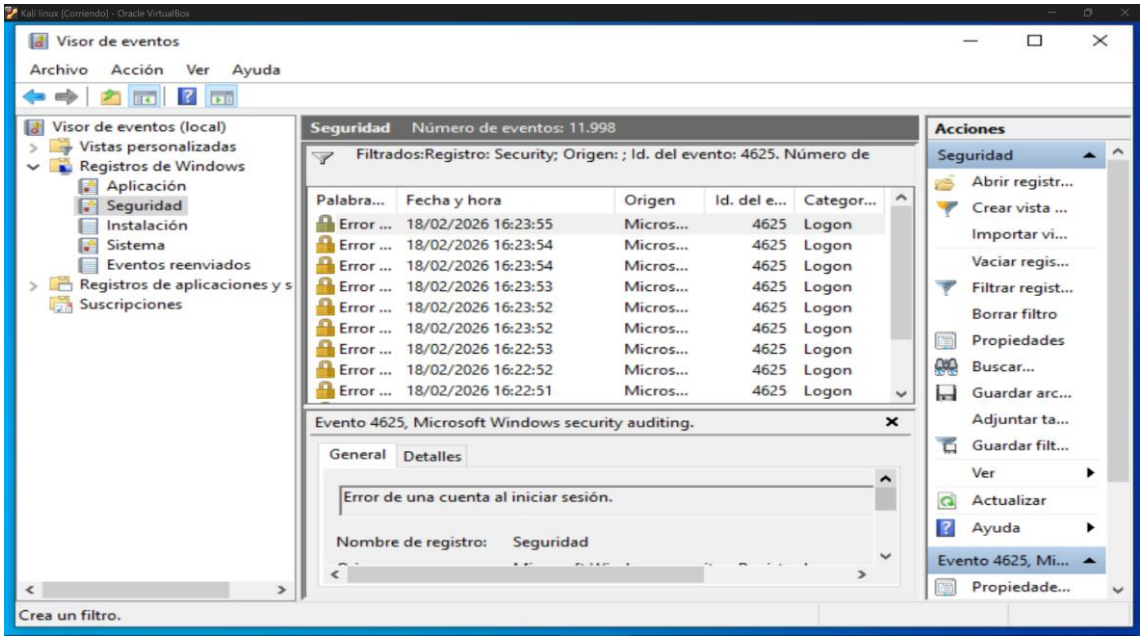
Se accede al Visor de eventos de Windows para analizar los registros de seguridad generados tras la simulación de intentos fallidos de autenticación RDP.



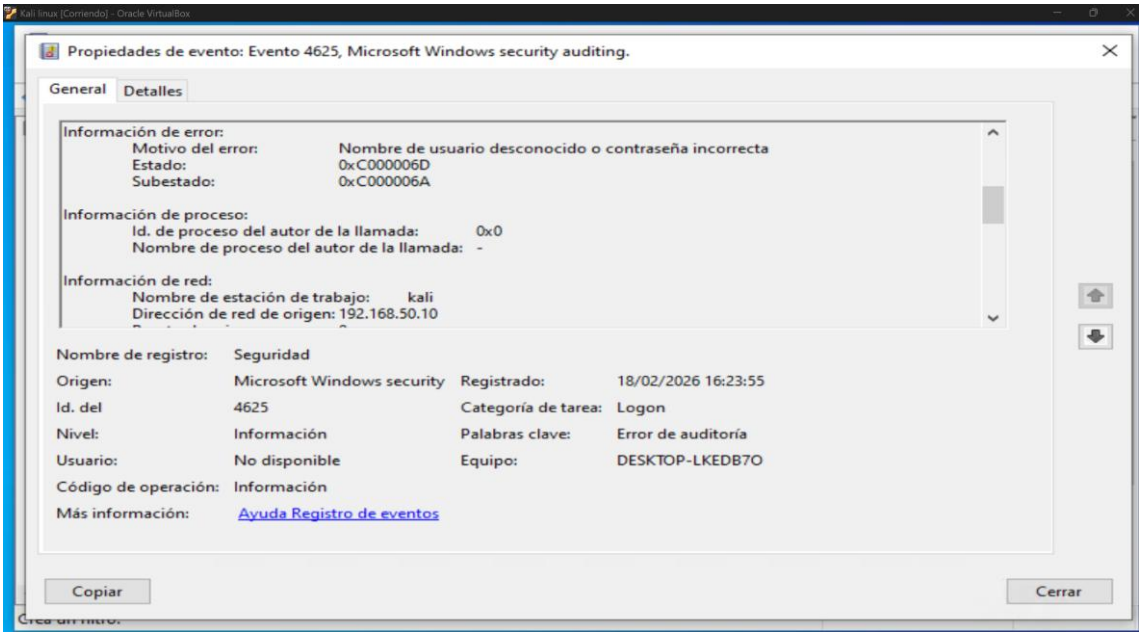
Se accede al registro “Seguridad”, donde Windows almacena eventos relacionados con autenticación, accesos, errores y auditoría.



Se filtran los eventos con ID 4625, que corresponden a errores de inicio de sesión. Se observan múltiples intentos fallidos en un corto intervalo de tiempo, lo que puede indicar un posible ataque de fuerza bruta.



El evento 4625 muestra un error de inicio de sesión con tipo 3 (Logon de red).
Esto indica que el intento de autenticación se realizó remotamente a través de red.
La dirección IP de origen 192.168.50.10 corresponde al equipo Kali atacante.
El motivo del error indica “Nombre de usuario desconocido o contraseña incorrecta”, lo que confirma que las credenciales fueron rechazadas.
La repetición consecutiva de estos eventos en un intervalo corto de tiempo es consistente con un patrón de ataque de fuerza bruta.



8) Evaluación del incidente y medidas correctivas

8.1 Evaluación del riesgo

El análisis de los eventos de seguridad (ID 4625) ha confirmado múltiples intentos fallidos de autenticación contra la cuenta LAB-SOC, procedentes de la dirección IP 192.168.50.10**.**

Las características observadas indican:

- Múltiples intentos en corto intervalo de tiempo.
- Tipo de inicio de sesión 3 (Logon de red).
- Credenciales incorrectas repetidas.
- Origen externo al sistema (equipo Kali).

Este patrón es consistente con un ataque de fuerza bruta contra el servicio RDP**.**

8.3 Medidas de mitigación recomendadas

1. Bloqueo automático por intentos fallidos

Configurar políticas de cuenta:

- Bloqueo tras 3–5 intentos fallidos.
- Tiempo de desbloqueo automático.

2. Restricción de acceso RDP

- Limitar RDP solo a IPs autorizadas.
- Cambiar puerto por defecto (3389).
- Implementar VPN antes de permitir RDP.

3. Implementación de autenticación multifactor (MFA)

Añadir doble factor para accesos remotos.

4. Monitorización continua

- Alertas automáticas ante múltiples eventos 4625.
- Correlación en SIEM.
- Revisión periódica de logs.

4. Monitorización continua

- Alertas automáticas ante múltiples eventos 4625.
- Correlación en SIEM.
- Revisión periódica de logs.

9) Conclusión general del proyecto

En este proyecto se ha simulado un ataque de fuerza bruta contra el servicio RDP en un entorno de laboratorio controlado, utilizando Kali Linux como máquina atacante y Windows como sistema víctima.

A través del análisis del Visor de eventos de Windows, se identificaron múltiples eventos 4625 correspondientes a intentos fallidos de inicio de sesión. Se determinó la dirección IP de origen (192.168.50.10), el tipo de inicio de sesión (tipo 3 – acceso de red) y el motivo del error (contraseña incorrecta). No se produjo ningún acceso exitoso al sistema.

El proyecto ha permitido desarrollar habilidades propias de un Analista SOC, como la interpretación de logs, la identificación de indicadores de compromiso (IOC), la correlación de eventos y la evaluación del nivel de riesgo.

En conclusión, el laboratorio demuestra la importancia de la monitorización y del análisis de registros de seguridad para detectar y responder ante intentos de acceso no autorizado en entornos empresariales.